

QuoteCraft Architecture Review

Executive Summary

- QuoteCraft is a Silver-tier internal microservice handling Restricted data (PII and financial), deployed on AlphaPaaS AWS with Azure-managed Postgres and AWS-managed Redis/EFS.
- Multiple critical gaps exist in security (secrets, encryption, RBAC), availability (single-AZ resources, deprecated configs), and cost (oversized non-prod, unused provisioned throughput).
- Scalability is limited by in-memory rate limiting and lack of connection pooling, risking performance at forecasted peak loads.
- Remediation actions are well-defined and actionable, with several tracked in backlog tickets but not yet scheduled.
- Evidence is comprehensive, but some documentation (runbook, manifests) contradicts architecture claims, especially around exposure and resource configuration.

Findings

Cost

F-01: Non-production environment exceeds cost threshold

- Severity: Critical
- Dimension: Cost
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "The FinOps team flagged in March 2026 that QuoteCraft's non-production environment is consuming approximately 35% of what production consumes."
- Policy reference: FIN-07
- Why it matters: Exceeding 20% triggers a FinOps review and risks budget approval; indicates waste or misconfiguration.
- Remediation: Investigate non-prod sizing and scheduling; downsize resources and enforce off-hours shutdown.
- Confidence: High

F-02: Provisioned throughput EFS not justified

- Severity: High
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/efs.tf
- Quote: "Provisioned throughput. Originally set during the pilot when we thought PDF generation would be I/O bound. It isn't. Tracked in QC-211."
- Policy reference: FIN-06
- Why it matters: Unjustified provisioned throughput increases monthly storage costs.
- Remediation: Switch EFS to standard throughput mode unless a documented IOPS requirement exists.
- Confidence: High

F-03: No S3 lifecycle policy for quote archives

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/s3.tf
- Quote: "# NB: No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely. There was a ticket to add glacier transition (QC-134) but it was deprioritised."
- Policy reference: FIN-13
- Why it matters: Keeping archives in standard storage increases long-term costs; cold data should transition to Glacier.
- Remediation: Implement S3 lifecycle policy to transition archived PDFs to Glacier after retention period.
- Confidence: High

F-04: Oversized production database

- Severity: Low
- Dimension: Cost
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "Azure PostgreSQL Flexible Server — SKU: GP_Standard_D16s_v3 (16 vCPU, 64 GB RAM)... Forecast growth: approximately 2× over the next 18 months."
- Policy reference: FIN-04
- Why it matters: Current sizing may be justified for forecasted growth, but should be monitored for actual utilisation.
- Remediation: Review database utilisation monthly; downsize if average CPU <30% unless justified.
- Confidence: Medium

Security

F-05: Secrets exposed via environment variables

- Severity: Critical
- Dimension: Security

- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "envFrom: ... secretRef: ... env: ... valueFrom: secretKeyRef: ... AWS_ACCESS_KEY_ID ... AWS_SECRET_ACCESS_KEY"
- Policy reference: CKS-11, DCH-07
- Why it matters: Secrets in environment variables risk disclosure via logs, dumps, and process listings.
- Remediation: Refactor deployment to mount secrets as file volumes using CSI driver or External Secrets Operator.
- Confidence: High

F-06: Use of long-lived IAM user access keys

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "# Long-lived IAM user access keys for reading from AWS Secrets Manager and mounting EFS. Created by the initial platform onboarding. There's a ticket to migrate to IRSA (QC-203) but it's not scheduled yet."
- Policy reference: AHS-11, ASC-06
- Why it matters: Long-lived credentials are prohibited; workload identity federation is required for cloud API access.
- Remediation: Migrate to IRSA (IAM Roles for Service Accounts) for AWS access; decommission IAM user keys.
- Confidence: High

F-07: RBAC Role grants wildcard permissions

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/rbac.yaml
- Quote: "rules: ... apiGroups: [\"*\"] resources: [\"*\"] verbs: [\"*\"]"
- Policy reference: CKS-14

- Why it matters: Wildcard permissions violate least privilege and CIS benchmarks; risk lateral movement.
- Remediation: Restrict Role to only required resources and verbs; remove wildcards.
- Confidence: High

F-08: Redis transit encryption disabled

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "# NB: TLS in transit is not enabled. Enabling it would require an application change (rediss:// URL and CA bundle). Tracked in QC-176."
- Policy reference: ASC-03, ASC-05, DCH-04
- Why it matters: Session cache contains Restricted data; unencrypted transit risks data exposure.
- Remediation: Enable Redis TLS in transit; update application to use rediss:// and CA bundle.
- Confidence: High

F-09: Postgres accessed via public FQDN, not Private Endpoint

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/configmap.yaml
- Quote: "POSTGRES_HOST: \"quotecraft-db.postgres.database.azure.com\" ... Private Endpoint is provisioned ... DNS record is pending ... Until then we use the public FQDN, which Azure routes over the public internet."
- Policy reference: AHS-15, ASC-03, DCH-10
- Why it matters: Public FQDN bypasses private connectivity, risking data egress and breaking residency guarantees.
- Remediation: Complete DNS setup for Private Endpoint; update application to use private hostname.
- Confidence: High

F-10: TLS certificate verification disabled for external API

- Severity: Medium

- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/integrations/bureau.py
- Quote: "response = requests.post(..., verify=False) ... TODO(QC-189): migrate to verify=True"
- Policy reference: DCH-05
- Why it matters: Disabling certificate verification risks MITM attacks and data compromise.
- Remediation: Add Atlas CA to trust store; enable verify=True for bureau API calls.
- Confidence: High

F-11: Sensitive payloads logged on exception

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/api/quotes.py
- Quote: "# Log the full payload so Support can reproduce the failure. (Flagged in the Feb 2026 security spot-check; QC-188 will redact.)"
- Policy reference: DCH-06
- Why it matters: Logging PII or credentials on error risks data leakage.
- Remediation: Implement payload redaction before logging; ensure no PII or credentials are logged.
- Confidence: High

Scalability

F-12: In-memory rate limiter not safe for multi-replica scaling

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/middleware/rate_limit.py
- Quote: "Thread-safe within a single process. This is the same implementation we've used since pilot. It works well for single-replica deployments; horizontal scaling will be addressed in QC-201."
- Policy reference: ARS-14
- Why it matters: Rate limiting is not consistent across pods; scaling out causes quota enforcement

failures.

- Remediation: Externalise rate limiter state to Redis or another distributed store; refactor middleware.
- Confidence: High

F-13: Database connection pool not implemented

- Severity: Medium
- Dimension: Scalability
- Evidence:
 - Source: app/src/quotecraft/db.py
 - Quote: "# TODO(QC-142): migrate to psycpg_pool.ConnectionPool ... For now we open a connection per request; at low baseline traffic this is acceptable, but the capacity plan anticipates 400 req/s at peak which we have not yet stress-tested."
- Policy reference: ARS-06
- Why it matters: Opening a new connection per request risks exhaustion and degraded performance at peak load.
- Remediation: Implement connection pooling (psycpg_pool) and tune pool size for expected throughput.
- Confidence: High

F-14: Redis single-node, single-AZ deployment

- Severity: Medium
- Dimension: Scalability
- Evidence:
 - Source: app/infra/aws/elasticache.tf
 - Quote: "num_cache_nodes = 1 ... availability_zone = \"\${var.aws_region}a\""
- Policy reference: ARS-18
- Why it matters: Single-node Redis cannot scale horizontally and is a bottleneck for session cache.
- Remediation: Deploy Redis replication group across multiple AZs; enable autoscaling if supported.
- Confidence: Medium

Availability

F-15: Application deployment uses 1 replica, lacks multi-AZ distribution

- Severity: Critical
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "replicas: 1 ... nodeSelector: failure-domain.alpha.pas.com/zone: \"1\""
- Policy reference: ARS-02, ARS-05
- Why it matters: Silver tier requires minimum 3 replicas and multi-AZ distribution; single replica risks outage.
- Remediation: Update deployment to 3+ replicas; configure topologySpreadConstraints for AZ distribution.
- Confidence: High

F-16: Use of deprecated DeploymentConfig for worker pods

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/worker-deploymentconfig.yaml
- Quote: "kind: DeploymentConfig ... The legacy DeploymentConfig resource MUST NOT be used for new deployments"
- Policy reference: ARS-03, ARS-23
- Why it matters: Deprecated resources must be migrated; risk platform support and resilience.
- Remediation: Migrate worker pods to apps/v1 Deployment resource.
- Confidence: High

F-17: Postgres lacks zone-redundant high availability

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "# Zone-redundant HA is not configured. ... The HA configuration has not yet been revisited since the initial pilot."
- Policy reference: ARS-18, ASC-03

- Why it matters: Single-zone database risks data loss and outage on AZ failure; violates Silver tier.
- Remediation: Enable zone-redundant HA for Azure Postgres Flexible Server.
- Confidence: High

F-18: Redis lacks multi-AZ replication

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "num_cache_nodes = 1 ... availability_zone = \"\${var.aws_region}a\""
- Policy reference: ARS-18, ASC-03
- Why it matters: Single-AZ Redis risks outage and data loss on AZ failure.
- Remediation: Deploy Redis replication group with nodes in multiple AZs.
- Confidence: High

F-19: Disaster recovery exercise not performed

- Severity: Medium
- Dimension: Availability
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "DR testing Not yet performed. Scheduled for Q3 2026."
- Policy reference: ARS-20
- Why it matters: Silver tier requires annual DR exercise; lack of testing risks unproven recovery.
- Remediation: Schedule and execute DR exercise; document outcome in runbook.
- Confidence: High

Highest Priority Next Actions

1. Refactor deployment to mount secrets as file volumes, not environment variables (CKS-11, DCH-07).
2. Migrate AWS access to IRSA (IAM Roles for Service Accounts); decommission long-lived IAM user keys (AHS-11, ASC-06).
3. Update application deployment to 3+ replicas with multi-AZ distribution (ARS-02, ARS-05).

4. Enable Redis transit encryption and multi-AZ replication; update application to use rediss:// (ASC-03, ASC-05, ARS-18).
5. Complete DNS setup for Azure Postgres Private Endpoint; update application to use private hostname (AHS-15, ASC-03).

Report Quality Check

- Findings are grouped by Cost, Security, Scalability, Availability. ****Pass****
- Every finding cites at least one evidence source. ****Pass****
- Every finding cites at least one policy clause. ****Pass****
- Findings are specific to QuoteCraft, not generic cloud advice. ****Pass****
- Recommendations are concrete enough for backlog tickets. ****Pass****